חלק א': שאלה פתוחה - 28 נקודות

בחלק זה שאלה אחת. יש להשיב **במקום המיועד בטופס הבחינה בלבד**.

א. אחת הביקורות כנגד ביטקוין היא צריכת החשמל האדירה שמעורבת בו, דבר ש(באופן כללי) אינו ידידותי לסביבה (אינו "ירוק" מספיק). למשל, לאחרונה, אחת מהחברות הגדולות בעולם הודיעה שתתחיל לקבל תשלומים בביטקוין, אך כמה חודשים לאחר מכאן החליטה לחזור בה מהחלטה זו, בטענה שהיא מודאגת מההשלכות הסביבתיות שיש למכרות הביטקוין על הסביבה, ושבעתיד היא מעוניינת לאמץ מטבעות קריפטוגרפיים – אך ידידותיים לסביבה.

מתוך ראייה "ירוקה" (כלומר, סביבתית), מציעים לשנות את אופן הפעולה של הרשת באופן הבא: פעולת כרייה של בלוקים חדשים תתבצע רק כאשר ישנן טרנזקציות חדשות להוסיף. אם אין טרנזקציות חדשות, הMiners ושאר חברי הרשת לא יעשו דבר. כתוצאה מכך יהיה חסכון משמעותי של חשמל, כי יהיו פרקי זמן שבהם לminers לא יהיו טרנזקציות חדשות בשביל לנסות למצוא בלוקים חדשים. בנוסף, מגדירים "ערך סף", כלומר ערך מינימלי של כמות טרנזקציות בבלוק. בכך, ערך סף מספיק גדול יבטיח שיהיו פרקי זמן שבו הminerים לא יהיה להם מספיק טרנזקציות חדשות לבלוקים חדשים – ובכך הם לא יעשו דבר – ויהיה חסכון בחשמל.

האם לפתרון המוצע יש השלכות על משתמשי ביטקוין?

האם לפתרון המוצע יש השלכות על אבטחת הרשת?

נמקו.

<u>תשובה:</u>

לפתרון יש השלכות על משתמשי ביטקוין, כי הוא גורם שיקח הרבה יותר זמן לטרנזקציות להיכלל בבלוקצ'יין, שהרי יש זמן רב שלא מנסים כלל למצוא בלוקים חדשים שיוסיפו טרנזקציות חדשות לבלוקצ'יין, מה שיקשה על ביצוע עסקאות ועל הסקיילביליות של המערכת.

לפתרון יש השלכות על אבטחת הרשת, כי שום דבר לא מונע מהתוקף לכרות בלוקים בזמן שהאחרים לא כורים - כי כמות הטרנזקציות מתחת לערך הסף. זה נותן לתוקף יתרון משמעותי ומגדיל את הסיכויים שלו למצוא בלוקים חדשים - מה שיאפשר לו ליצור forkים שארוכים יותר מהשרשרת הנוכחית ויוביל לdouble spending.

ב. ג'וני התקין במשרדו נתב אלחוטי, אשר מגיע עם מספר כלים מובנים הניתנים להגדרה ולשימוש, ובהם: packet filter, שרת DHCP ושרת DNS. הנתב מנוהל על ידי ממשק web, אשר זמין בכתובת 10.0.0.2. ג'וני הגדיר שרק הפקיד/ה של המשרד יוכל להתחבר לממשק האינטרנטי, על ידי שהגדיר שתתבצע בדיקה בממשק שהחבילות מגיעות מכתובת ה MAC של המחשב של הפקיד/ה, ורק במקרה כזה לאשר גישה לניהול הנתב.

האם אופן ניהול הרשת של ג'וני כפי שמתואר לעיל טוב?

אם כן - יש לנמק מדוע.

אם לא, יש לתאר התקפה סבירה על הרשת על ידי תוקף שאינו חבר ברשת, שמנצלת את האופן שבו הרשת הוגדרה לעיל והציעו כיצד למנוע את ההתקפה הזו.

<u>תשובה:</u>

אופן הניהול אינו טוב.

הפקיד/ה שיגלשו לאתר בשליטת התוקף יריצו בדפדפן שלהם סקריפט שנכתב על ידי התוקף (למרות שהתוקף אינו חבר ברשת).

הסקריפט יכול לשלוח בקשות לממשק הניהול של הנתב, ומכיוון שהסקריפט רץ בדפדפן של הפקיד/ה, הן ישלחו לממשק הניהול עם כתובת הMAC של הפקיד/ה, ולכן ממשק הניהול יקבל אותן כתקינות.

זה בעצם התקפת csrf ולכן אפשר להגן עליה בעזרת מנגנוני ההגנה הרלוונטיים שלמדנו.

ג. בשאלה זו נעסוק בפרוטוקול המשמש את אליס ובוב להסכמה על מפתח סימטרי ביניהם. שימו לב, בפרוטוקול זה יוצאים מנק' הנחה שלאליס ובוב כבר יש ביניהם מפתח סימטרי ארוך טווח בשם KAB (כלומר, שמיועד לשימוש לזמן רב), ובעזרת פרוטוקול זה הם מעוניינים להחליט על תת-מפתח סימטרי שישמש אותם לשיחה הנוכחית. כלומר, תת-המפתח יהיה רלוונטי רק לחיבור הנוכחי.

הפרוטוקול:

1. אליס שולחת לבוב את השם שלה (A) ומספר אקראי שהיא בחרה (NA).
2. בוב מחזיר לאליס את המספר האקראי שבחרה מוצפן בעזרת המפתח הסימטרי ארוך הטווח ביניהם, ומספר אקראי שהוא בוחר (NB).
3. אליס מחזירה לבוב את המספר האקראי של בוב מוצפן בעזרת המפתח הסימטרי ארוך הטווח בניהם.
4. לבסוף, בוב מייצר את תת-המפתח עבור השיחה הנוכחית k, ושולח אותו מוצפן לאליס בעזרת המפתח הסימטרי ארוך הטווח ביניהם.

האם הפרוטוקול הנ"ל בטוח?

אם לא, הסבירו התקפה בה תוקף יכול לגרום לאליס לחשוב שהיא הקימה חיבור מאובטח בעזרת הפרוטוקול הנ"ל עם בוב, כאשר למעשה היא הקימה חיבור מול התוקף, והציעו דרך לתקן את הפרוטוקול כדי שיגן בפני ההתקפה.

אם כן, נמקו.

<u>תשובה:</u>

הפרוטוקול הנ"ל אינו בטוח.

בשלב 4, התוקף יכול להחליף את ההודעה שבוב שולח לאליס, ובמקום לשלוח לה את NA שהוצפן על ידי בוב בשלב 2. כשאליס תקבל אותו - היא תפענח אותו ותשתמש במה שיתקבל בתור תת-מפתח סימטרי לשיחה הנוכחית. מכיוון שאליס שלחה בשלב 1 את NA באופן גלוי, התוקף יודע אותו, ולכן יכול לתקשר עם אליס כאילו היה בוב.

פתרון: בשלב 4, אליס תצפה לקבל לא רק הצפנה של k, אלא יצורפו אליו גם NA ו NB. זה ימנע מהתוקף למחזר את NA שהוצפן על ידי בוב בשלב 2, כי אליס תטפל בהודעה זאת שונה - תפענח אותה ותבדוק שהיא מכילה את הNA ו NB שהיא מצפה להם - מה שלא יקרה בהתקפה הנ״ל.

ד. מחליטים לבצע שינוי לאופן שבו ביטקוין עובד. השינוי הוא שהחליטו להוריד חלק מהמידע שמופיע כרגע בבלוק – מה שיפנה מקום – מה שיאפשר לבלוק להכיל יותר טרנזקציות. מימשו את הפתרון באופן כזה שאם miner לא עידכן את התוכנה שתתמוך בפורמט החדש אזי הוא עדיין יכול לקבל בלוקים חדשים (מהפורמט החדש) ולבדוק את תקינותם ותקינות הטרנזקציות שבהם כאילו היו בלוקים מהפורמט הישן.

באיזה סוג של fork מדובר?

נמקו.

<u>תשובה:</u>

מדובר בsoft fork.

כורה שלא מעדכן את התוכנה עדיין יכול לקבל בלוקים חדשים, ולכן תמיד יכול לאמץ את השרשרת הארוכה יותר. (בניגוד ל hard fork שם מי שלא עדכן לא מקבל את הבלוקים החדשים ונשאר לכרות על שרשרת נפרדת ולא יכול לאמץ את השרשרת הנפרדת אם היא ארוכה יותר, כי מכילה בלוקים לפי הלוגיקה החדשה שאינה תומכת את הלוגיקה הישנה)

חלק ב': שאלות ברירה - 72 נקודות

בחלק זה 12 שאלות. משקל כל שאלה 6 נקודות. יש להשיב על כל השאלות. יש לסמן את התשובה הנכונה ביותר, בעט שחור או כחול בלבד באופן ברור ועל פי ההנחיות, **בדף הקידוד המצורף בלבד**.

(בכל השאלות הבאות, סעיף א הוא התשובה הנכונה)

<u>שאלה מספר 1:</u> (התקבלו כל הסעיפים)

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. בעיה גדולה ב One Time Pad היא העברת המפתחות

ב. בעיה גדולה ב Public Key Cryptography היא העברת המפתחות

ג. בעיה גדולה ב RSA היא העברת המפתחות

ד. בעיה גדולה ב Diffie Hellman היא העברת המפתחות

<u>שאלה מספר 2:</u>

תוקף הצליח לגנוב קובץ שמכיל סיסמאות לאימות של משתמשים. מטעמי אבטחה, כל הסיסמאות בו לא נשמרו כמות שהן, אלא הוחלפו בhash שלהן. איזה מבין ההתקפות הבאות ינסה התוקף לבצע כדי להשיג את הסיסמאות המקוריות דרך הקובץ הנ"ל?

א. התקפת brute force

ב. התקפת spoofing

ג. התקפת sql injection

ד. התקפת csrf

<u>שאלה מספר 3:</u>

איזו מבין הטענות הבאות נכונה?

א. בקריפטוגרפיה, MAC המיושם נכון מספק אמינות המידע

ב. בקריפטוגרפיה, מטרת השימוש בלCBC בצופן בלוקים היא לספק אמינות המידע

ג. בקריפטוגרפיה, CA חותם על המפתחות שהCA יצר עבור שרת האינטרנט שפנה אל הCA

ד. בקריפטוגרפיה, PKI נועד לוודא שימוש מאובטח ב ARP

<u>שאלה מספר 4:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. הגדרה נכונה של IDS מונעת התקפות DNS poisoning

ב. הגדרה נכונה של IPS מאפשרת להגיב להתקפות שזוהו

ג. הגדרה של מחשב עם מיפוי סטטי בין כתובות IP וכתובות MAC יכולה לסייע כנגד התקפות ARP poisoning/spoofing

ד. שימוש ב nmap יכול לסייע לזהות חולשות

<u>שאלה מספר 5:</u>

מניעת התקפת injection, <u>לא</u> תתבצע על ידי:

א. IDS

ב. חיטוי הקלט בצד השרת

ג. סינון קלט המשמש לביצוע שאילתת ה SQL

ד. חומת אש אפליקטיבית

<u>שאלה מספר 6:</u>

איזו מבין הטענות הבאות נכונה?

א. ב micro payments, אליס יודעת שבוב ישחרר לה את הכסף שמגיע לה (אחרת הוא יפסיד כסף)

ב. ב escrow transactions, המתווך חייב לאשר את העסקה כדי שהיא תהיה חוקית

ג. בביטקוין, להשתתף בתהליך כריית ביטקוין אם רוצים לבצע עסקאות בביטקוין

ד. בביטקוין, משתמשים ב One Time Pad בכדי לייצר את הארנקים

<u>שאלה מספר 7:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. ביצוע התקפת הרעלת DNS מחייבת יכולות MitM

ב. ביצוע התקפת הרעלת ARP אפשרית עם יכולות Off path

ג. ביצוע התקפת DDoS יכולה להתבצע בעזרת Mirai

ד. הצלחה בביצוע התקפת Syn flood קשה יותר אם משתמשים בSyn cookies

<u>שאלה מספר 8:</u>

איזה מבין הטענות הבאות נכונה בהקשר של חתימה דיגיטלית?

א. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפרטי של השולח. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפומבי של השולח והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

ב. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפומבי של השולח. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפרטי של השולח והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

ג. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפומבי של השולח. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפומבי של השולח והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

ד. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפרטי של השולח. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפרטי של השולח והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

<u>שאלה מספר 9:</u> (התקבל גם סעיף ב)

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. OCSP stapling הינו יעיל בזכות השימוש בעץ מרקל.

ב. OCSP stapling הינו מנגנון שונה לחלוטין מOCSP רגיל.

ג. ניתן לתמוך ב OCSP וגם ב CRL, ולא חייבים לבחור רק אחד מהם.

ד. השימוש ב CRL תורם לבטיחות של PKI.

<u>שאלה מספר 10:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. בהתקפת stored xss העובדה שהדפדפן מצרף cookies לבקשות מהותית.

ב. בהתקפת csrf השרת אינו יודע שהבקשה אינה באמת של הקורבן.

ג. שימוש ב x-frame-options אינו מיועד להגנה מפני sql injection.

ד. אחת מהדרכים להגן מפני התקפת csrf היא בעזרת CSRF token.

<u>שאלה מספר 11:</u>

איזו מבין הטענות הבאות נכונה?

א. ב TLS, משתמשים ב chain of trust

ב. לקוח הגולש לשרת foo.com מוודא את תקינות התעודה שקיבל מהשרת ע"י וידוא שהתעודה נחתמה באופן קריפטוגרפי חוקי ע"י foo.com

ג. שרת אינטרנט מייצר ניגש ל Root CA ומבקש ממנו לחתום על המפתח הפומבי של שרת האינטרנט

ד. שרת Root CA חותם ישירות על המפתח הפומבי של שרת האינטרנט

<u>שאלה מספר 12:</u>

איזו מבין הטענות הבאות נכונה?

א. ב CT, המוניטורים מנטרים את הלוגרים, והלוגרים מתחזקים לוג של תעודות שהונפקו על ידי CAים

ב. ב CT, המוניטורים מנטרים את הCAים, והלוגרים את המוניטורים

ג. ב CT, המוניטורים מנטרים את הלוגרים, והלוגרים את המוניטורים

ד. ב CT, הלוגרים מתחזקים לוג של תעודות שהונפקו על ידי CAים, והמוניטורים מנטרים את הCAים

--- סוף המבחן ---